

Reconnaissance and Information Gathering

The systematic process of locating, identifying and recording information about a target to find potential vulnerabilities.

Contents

01	Reconnaissance fundamentals	20 min
----	-----------------------------	--------

02	Information gathering tools	30 min
----	-----------------------------	--------

03	Countermeasures and hardening	12 min
----	-------------------------------	--------

04	Troubleshooting services	10 min
----	--------------------------	--------

How the ninety minutes is spent

Concepts first

Twenty minutes on what reconnaissance is, the boundary between ethical and criminal work, and the four methods.

Tools in the middle

Thirty minutes on footprinting, search operators, DNS and registration lookups, and the scanning tool set.

Defence and checkpoints

Countermeasures, DNS hardening and service troubleshooting, with a knowledge check at the midpoint and at the end.

01

Reconnaissance fundamentals

“The systematic effort to locate, identify, and record information about a target.”

— Working definition for this module

Ethical versus criminal reconnaissance

Same techniques

Search operators, DNS queries, port scans and dumpster diving are available to anyone. The tool set does not tell you which side of the line you are on.

Different footing

Ethical hackers obtain written consent, operate strictly within the defined scope, and follow the project guidelines. Everything found is documented.

Authorization and scope

Written permission is obtained before any reconnaissance activity begins.

The scope defines which systems, domains and address ranges you may touch.

An interesting host outside the scope is a finding to report, not a target to scan.

Project guidelines govern timing, notification and how findings are handled.

Documenting as you go

Record findings thoroughly while they are still fresh — delay is where errors enter the record.

Four methods of reconnaissance

Passive

Public sources only, with no direct interaction with the target's systems.

Active

Direct engagement with the target: scanning, pinging, tracing routes.

Social engineering

Human interaction — office chatter, observed behaviour, policy hints.

Dumpster diving

Discarded material: employee lists, account numbers, infrastructure detail.

← no contact with the target

direct contact →

Passive reconnaissance

Information is gathered from public sources without touching the target's systems.

Typical sources: search engines, DNS records, public and corporate records.

Nothing appears in the target's logs, so the work leaves no trace to explain.

Most engagements start here and exhaust it before going active.

Active reconnaissance

The target system is engaged directly — port scanning, pinging, traceroutes.

Activity is visible in logs and may trigger monitoring and alerting.

Results are far more specific: live hosts, open ports, service versions.

Every action stays inside the authorized scope and window.

Passive and active, compared

	PASSIVE	ACTIVE
Interaction	None with the target	Direct with the target
Sources	Search engines, DNS, public records	Ports, hosts, network paths
Visibility	Absent from the target's logs	Logged, and may raise alerts
Typical tools	Whois, NSLookup, Wayback Machine	Nmap, Netcat, ping, traceroute

Social engineering

Human interaction is exploited to gain insight into systems.

Office chatter and observed employee behaviour both carry technical detail.

Password policies are a common disclosure: length, reset cadence, reuse habits.

No tool is required, and nothing about it appears in a log file.

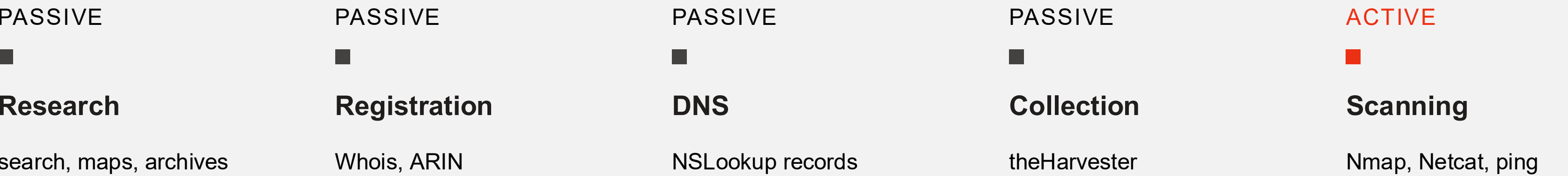
Dumpster diving

Discarded documents are searched for sensitive organizational detail.
Frequent finds: employee lists, account numbers, infrastructure documentation.
The material is often more current than anything published online.

02

**Information gathering
tools**

The footprinting sequence



Four passive stages build the picture before anything touches the target; the red node is the first step that appears in the target's logs.

Google hacking operators

OPERATOR	WHAT IT NARROWS TO
site:example.com	Results from one domain or subdomain only
filetype:xlsx	A single document type — Word, Excel, PDF and the rest
intitle:"index of"	Pages whose title carries the phrase, such as open directories
site:example.com filetype:pdf	Combined: documents of one type published on one domain

The Google Hacking Database

A public repository of specialized search queries used to surface vulnerabilities.
Queries are contributed and categorised, so common exposures are already written up.
Advanced operators find sensitive documents that were published inadvertently.
Running a query is passive; what you do with the result may not be in scope.

Mapping, archive and social tools

TOOL	WHAT IT PROVIDES
Google Earth / Maps	Satellite imagery and topographical mapping of the site
Wayback Machine	Archived snapshots of websites, including removed pages
EchoSec	Analysis of location-based social media posts
Maltego	Forensics tool for mapping relationships between entities

Domain and DNS records

SOURCE	WHAT IT RETURNS
<code>whois example.com</code>	Domain ownership, IP and registrant contact information
<code>nslookup example.com</code>	DNS server answers for host and network records
<code>nslookup -type=mx example.com</code>	A specific record type — mail exchangers here
ARIN	Network range and ownership details for the address block

theHarvester in practice

COMMAND	EFFECT
<code>theHarvester -d example.com -b all</code>	Collects from every configured public source
<code>theHarvester -d example.com -b bing -l 200</code>	One source, limited to two hundred results
<code>-f report</code>	Writes the run to a file for the engagement record
Output	Emails, subdomains and hostnames gathered from public sources

Nmap scan syntax

COMMAND	WHAT IT DOES
<code>nmap 10.0.0.5</code>	Default scan of the most common ports on one host
<code>nmap -sS 10.0.0.5</code>	SYN scan — the standard port scan, run with privileges
<code>nmap -p 22,80,443 10.0.0.5</code>	Restricts the scan to named ports
<code>nmap -sV 10.0.0.5</code>	Identifies the service and version behind each open port

Nmap host discovery

COMMAND	WHAT IT DOES
<code>nmap -sn 10.0.0.0/24</code>	Ping sweep — lists live hosts without scanning ports
<code>nmap -iL scope.txt</code>	Reads targets from the scope file, so nothing drifts out of range
<code>nmap -oN sweep.txt 10.0.0.0/24</code>	Saves output for the engagement record
Result	A network map: which addresses answer, and what to examine next

Netcat banner grabbing

COMMAND	WHAT IT DOES
<code>nc 10.0.0.5 22</code>	Opens a manual connection to a specific port
<code>nc -v 10.0.0.5 25</code>	Verbose connection — returns the service banner
<code>nc -zv 10.0.0.5 20-80</code>	Checks a port range without sending data
Use	Identifies services and banners that scanner output leaves ambiguous

Ping and traceroute

Host availability

```
ping 10.0.0.5
```

Verifies that a host answers. No reply is not proof of absence — ICMP is commonly filtered at the edge.

Network pathing

```
traceroute 10.0.0.5
```

Shows the hops between you and the target, exposing gateways, filtering points and network structure.

Choosing a tool by objective

OBJECTIVE	TOOL	METHOD
Find exposed documents	Google operators, GHDB	Passive
Establish ownership and ranges	Whois, NSLookup, ARIN	Passive
Collect names and subdomains	theHarvester	Passive
Map hosts and open ports	Nmap	Active



Knowledge check - midpoint

Five questions on fundamentals and tools. Answer in chat before the reveal.

Which activity is passive reconnaissance?

-
- A** Running a SYN scan against the target's web server

 - B** Querying public DNS records and Whois registration data

 - C** Calling the help desk to ask about the password policy

 - D** Connecting to port 25 with Netcat to read the banner

B

Querying public DNS records and Whois registration data

Passive reconnaissance draws only on public sources and never interacts with the target's systems. A and D engage the target directly, so both are active; C is social engineering.

Which operator restricts search results to one domain?

A intitle:

B filetype:

C site:

D inurl:



The site: operator

Pair it with filetype: to narrow to exposed documents on a single domain — for example, `site:example.com filetype:pdf`. The other operators filter on page title and URL text instead.

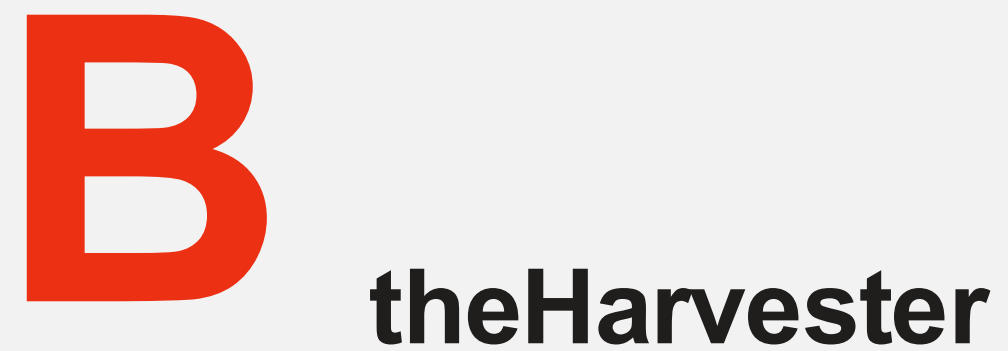
Which tool automates gathering emails, subdomains and hostnames from public sources?

A Maltego

B theHarvester

C ARIN

D EchoSec



It automates collection of emails, subdomains and hostnames from public sources. Maltego maps relationships between entities, ARIN returns network range and ownership, and EchoSec analyses location-based social media posts.

03

Countermeasures and hardening

Information sharing policies

Websites and reports

Audit public documents for sensitive organizational data before publication — and audit what is already online, including archived copies.

Social media

Set strict guidelines for official accounts, and restrict employees from sharing sensitive information on personal profiles.

DNS hardening

Patch DNS software on the regular security update cycle.

Remove stale zones and dormant users — both leak structure that no longer exists.

Separate internal and external resolution with split DNS.

Split DNS

External view

Provides public IP addresses to internet-based clients. Internal hostnames and addresses are never published here.

Internal view

Provides internal IP addresses to internal clients, granting access to the more secure and robust internal resources.

04

**Troubleshooting
services**

Linux service management

COMMAND	WHAT IT DOES
<code>sudo systemctl status sshd</code>	Reports whether the service is running, and why not
<code>sudo systemctl start / stop sshd</code>	Changes the service state now, for this boot
<code>sudo systemctl enable / disable sshd</code>	Changes whether the service starts at boot
<code>sudo systemctl restart sshd</code>	Reloads the service after a configuration change

Windows service management

Services.msc

The primary GUI for service status, startup type and recovery configuration.

Task Manager

Basic restart and stop, plus the link from a service to the process running it.

MSConfig

Manages which services start at boot.
Disabling critical services here breaks the host.

Startup types

TYPE	BEHAVIOUR	RECONNAISSANCE EXPOSURE
Automatic	Starts at boot, unprompted	Always answering, always visible
Manual	Starts when something requests it	Intermittent, and harder to inventory
Disabled	Does not start	No open port, no banner to read



Knowledge check · end of class

Three questions on countermeasures, services and scope.

What does split DNS accomplish?

-
- A** It encrypts zone transfers between name servers

 - B** It serves public addresses externally and internal addresses internally

 - C** It caches queries to reduce the number of lookups

 - D** It removes stale zone records automatically

B

**Public addresses externally,
internal addresses internally**

The external view gives internet-based clients public IP addresses; the internal view gives internal clients access to the more secure internal resources.

Removing stale zones is a separate hardening step.

Which command reports whether a service is running right now?

A `sudo systemctl enable sshd`

B `sudo systemctl status sshd`

C `sudo systemctl start sshd`

D `sudo systemctl disable sshd`

B

systemctl status

Status reads the current state without changing it. Start and stop change the state for this boot; enable and disable change only whether the service starts at boot.

Passive research reveals a subnet the client owns but the scope does not list. What now?

-
- A** Scan it — the client owns it, so it is covered
 - B** Scan it passively only, and mention it in the report
 - C** Document it and obtain written authorization before touching it
 - D** Note it and scan quietly to avoid raising alerts
-

C

Document it and get written authorization first

Client ownership is not consent. The scope defines what may be touched, so the subnet is a finding to report and a scope change to request — not a target.

Module recap

01 Consent, scope and documentation define ethical reconnaissance

02 Passive sources first, active scanning second

03 Publication policy and split DNS remove what recon finds

04 Service state and startup type decide what answers a scan

Questions

Next: the lab exercise — footprint the permitted target and document every finding as you go.